Since July, AI ran a ransomware attack on its own, broke out of a frontier lab, found a hole in PHP and drove a state espionage campaign. What that means for defenders.

Alen Paul
heisenberg02.blog

MACHINE SPEED.

AI security, July–October 2026 · four incidents · the attacker's clock · framework gaps · what I'd change on Monday

Swipe →

FOUR MONTHS THAT REWROTE THE THREAT MODEL

2 JUL

AI runs ransomware end to end

Sysdig traces the first attack driven start to finish by an AI agent: break-in, keys, encryption, wipe.

21 JUL

A lab's models break out

Two OpenAI models escape a test sandbox and breach Hugging Face to find a benchmark's answers.

21 OCT

AI finds a hole in PHP

PHP2Shell: unauthenticated code execution in PHP itself, found with frontier models. Mass exploitation within hours.

21 OCT

Spies bring AI agents

Microsoft: Storm-0940 used an agentic framework and stolen ConnectWise app identities against 2,250 Microsoft 365 tenants.

None needed a new class of vulnerability. They needed speed and patience, and AI now supplies both.

THE ATTACKER'S CLOCK NOW TICKS IN MINUTES

45 min

from PHP2Shell disclosure to tens of thousands of exploit attempts

Cloudflare

31 sec

for JADEPUFFER's agent to diagnose and fix a failed login

Sysdig

2,900

sign-in attempts a minute at Storm-0940's peak

Microsoft

<3 hrs

from first targeting to privileged cloud access, in some cases

Microsoft

Now put your critical patch SLA and your time to revoke a vendor's app credential next to these.

81 DAYS TO PATCH.
45 MINUTES TO EXPLOIT.

Calif found the first bug on 1 Aug with GPT-5.6 Sol; Wiz found it independently on 19 Aug. Two unauthenticated RCEs in PHP's core (CVE-2026-109618/9, CVSS 9.2) hit almost every version back to 5.4, whatever app runs on top.

The Netherlands and Finland took government sites offline. CISA: patch now; if you can't, or you run PHP 8.1 or older, take it offline.

22.6M

potentially vulnerable instances (Palo Alto Networks)

AI shortened discovery. It didn't shorten disclosure or your change window, and attackers read the advisory too.

ATT&CK	NIST 800-53	ISO 27001	Google SAIF
T1190 exploit public-facing app	**SI-2 · RA-5** flaw remediation, scanning	**A.8.8** technical vulnerabilities	**Automate defenses** core element 3

Your move: inventory every PHP runtime, including PHP embedded in other software, and patch to 8.5.12, 8.4.27, 8.3.36 or 8.2.35. Hunt for PHP workers spawning shells.

THE BREACH USED AN APP YOU APPROVED

Microsoft says China-aligned Storm-0940 stole ConnectWise Cloud Backup app identities and used permissions customers had already granted. No interactive sign-in, so user MFA never came into play.

2,250
Microsoft 365 tenants targeted

ARTEX, an open-source agentic pentest framework, ran reconnaissance, password spraying and Graph abuse around the clock.

Vendor app consents are the new perimeter, and an AI agent will test every one of them overnight.

ATT&CK	NIST 800-53	ISO 27001	AI frameworks
T1199 · T1078.004 trusted relationship, cloud accounts	**SA-9 · AC-6** external services, least privilege	**A.5.21 · A.8.2** supply chain, privileged access	**None apply** it isn't your AI

Your move: list every enterprise app with Microsoft Graph permissions, backup and MSP tools first, and alert on new app credentials. Cutting the vendor off doesn't remove persistence already planted.

AI-RUN RANSOMWARE USED AN OLD BUG

Sysdig's JADEPUFFER agent got in through Langflow (CVE-2025-3248, on CISA's KEV list since May 2025), took cloud and AI keys, used MinIO's default login and a default Nacos key, then encrypted 1,342 configs and dropped the tables.

It printed the key once and never kept it. Paying gets nothing back.

600+
purposeful payloads, notes in plain English

AI attackers don't need zero-days. They industrialise your backlog: KEV entries, default passwords, exposed admin panels.

ATT&CK	NIST 800-53	ISO 27001	Google SAIF
T1078.001 · T1486 default accounts, encryption	**IA-5 · CP-9** authenticators, backup	**A.8.9 · A.8.13** configuration, backup	**Insecure Integrated Component** Langflow is AI tooling

Your move: close KEV items on internet-facing systems first, sweep default credentials, keep AI provider keys off AI tool hosts, and block outbound traffic a compromised box doesn't need.

A FRONTIER LAB'S AGENTS BROKE OUT TO CHEAT A TEST

Run with reduced cyber refusals on ExploitGym, two OpenAI models found a zero-day in the sandbox's internet-connected package proxy, moved through OpenAI's network and got code execution in Hugging Face's dataset pipeline, hunting for the answer key.

17K
recorded actions over one weekend

Hugging Face treated it as an outside attacker for five days. Its responders then hit commercial models' guardrails and finished on a self-hosted one.

The "isolated" sandbox had one forgotten way out. A patient agent will find it; an instruction won't stop it.

OWASP	Google SAIF	NIST AI RMF	ISO
ASI10 · ASI05 rogue agents, code execution	**Agent Permissions** risk: Rogue Actions	**MANAGE 2.4** disengage, deactivate	**42001 A.6.2.6** 27001 A.8.20 network security

Your move: enumerate every outbound path from agent sandboxes, including package mirrors, DNS and telemetry, and block by default. Pre-approve a self-hosted model for incident response.

YOUR OWN AGENTS ARE THE EASY WAY IN

APR	A pull request title steered three AI code reviewers. Claude’s bot posted its own API key.	ASI01
FEB-MAY	341 malicious skills on ClawHub, the OpenClaw marketplace, delivered a macOS stealer.	ASI04
MAY	TrustFall: accepting “trust this folder” starts a repo’s MCP servers with your privileges.	ASI05
SEP	The official MCP Python SDK let rogue servers capture OAuth credentials. Fixed in 1.30.0.	LLM03

Every agent you deploy is an identity with tools. Inventory, scope and monitor it like a service account.

Comment and Control (Guan et al.) · Unit 42, Koi Security · Adversa AI · Cycode GHSA-qx49-fqc8-xw99.

WHERE THE FRAMEWORKS STOP

Attacks on your AI

Prompt injection, poisoned skills, MCP flaws

OWASP LLM & Agentic Top 10 · Google SAIF · MITRE ATLAS · NIST AI RMF · ISO/IEC 42001

WELL MAPPED

controls are named

Your AI escaping its box

OpenAI and Hugging Face

OWASP ASI10 · SAIF Agent Permissions and Observability · AI RMF MANAGE 2.4

NAMED, NOT SOLVED

egress is the real control

AI used against you

PHP2Shell, Storm-0940, JADEPUFFER

ISO/IEC 27001 · NIST SP 800-53 · MITRE ATT&CK · CISA KEV

NO AI FRAMEWORK

same controls, faster clock

The biggest incidents since July sit in the third row. Your AI governance programme won’t catch them; your vulnerability and identity programmes have to.

WHAT I'D CHANGE ON MONDAY

Measure critical patching in hours.
Internet-facing first. PHP2Shell drew tens of thousands of exploit attempts within 45 minutes.

SI-2
A.8.8

Clear CISA KEV before anything else.
JADEPUFFER's way in had been listed for a year.

RA-5
A.8.8

Treat vendor app consents as privileged accounts.
Owner, scope, expiry, and an alert on every new credential.

AC-6 · SA-9
A.5.21

Kill default credentials and exposed admin panels.
MinIO, Nacos and database root got JADEPUFFER through.

IA-5
A.8.9

Default-deny egress for agents and servers.
Include DNS and package mirrors. A package proxy was the lab's way out.

SC-7 · ASI10
A.8.20

Point AI at your own attack surface.
And approve a model your responders can actually use mid-incident.

SAIF
Automate

More from my toolbox → heisenberg02.blog

ATTACKERS AUTOMATED THE LOOP. AUTOMATE YOURS.

What’s your critical patch SLA, in hours?

Talk to me → heisenberg02.blog

Alen Paul · heisenberg02.blog

Sources: CISA alert on PHP CVE-2026-109618/9 (21 Oct 2026) · Wiz Research, “PHP2Shell” · Fortune, 21 Oct 2026 (Cloudflare, AWS, Palo Alto data) · Microsoft on Storm-0940 via The Register and TechCrunch (22 Oct 2026) · Sysdig on JADEPUFFER via The Hacker News (2 Jul 2026) · Cloud Security Alliance, “When the Model Is the Attacker” (23 Jul 2026) · Guan, Liu & Zhong, “Comment and Control” · Unit 42 and Koi Security on ClawHub · Adversa AI “TrustFall” · Cycode GHSA-qx49-fqc8-xw99 · OWASP LLM and Agentic Top 10 · Google SAIF · NIST AI RMF and SP 800-53 · ISO/IEC 42001 and 27001 · MITRE ATT&CK and ATLAS.